

Datasenterveileder

I ekomloven som trådte i kraft 1. januar 2025 ble det innført bestemmelser som regulerer sikkerhet og beredskap i datasentre lokalisert i Norge. Denne veiledningen gir en beskrivelse av hvordan ekomloven og Forskrift om datasenter (datasenterforskriften) regulerer datasentre i Norge. Reguleringen dekker kommersielle datasentre og virksomhetsinterne datasentre med en samlet abonnert elektrisk effekt over 0,5 MW.

01.06.2026

Målgruppen for veilederen er kommersielle datasenteroperatører og virksomheter som driver virksomhetsintern datasentre som er omfattet av reguleringen. Veilederen gir en innføring i sikkerhets- og beredskapsbestemmelsene i ekomloven og datasenterforskriften.

Videre tegnes det i veilederen opp en avgrensning mot annen regulering, slik som ivaretagelse av sikkerhet i forbindelse med samlokalisering i telelosjiannelegg, som er regulert i andre bestemmelser i ekomloven og klassifiseringsforskriften.

1 Formålet og virkeområde til reguleringen

1.1 Formålsparagraf

§ 1-1. Formål

Lovens formål er å sikre brukerne i hele landet gode, rimelige og fremtidsrettede elektroniske kommunikasjonstjenester med forsvarlig sikkerhet, legge til rette for bærekraftig konkurranse og effektiv bruk av samfunnets ressurser og stimulere til næringsutvikling og innovasjon. **Loven skal også gi forsvarlig sikkerhet i datasentre.**

Formålet til ekomloven er tatt inn i [ekomloven § 1-1](#). Der fremgår det at forsvarlig sikkerhet i datasentre er del av lovens formål. For å oppnå dette er det f.eks. krav om at datasenteroperatører skal opprettholde forsvar beredskap og prioritere viktige samfunnsaktører ved behov, jf. § 3-7 om datasenter.

Datasenterforskriften § 1-1. Virkeområde

Forskriften gjelder for datasenteroperatører som definert i ekomloven § 1-5 nr. 38.

1.2 Virkeområde

[Ekomloven § 1-5 nr. 38](#) .datasenteroperatør: fysisk eller juridisk person som

- a. tilbyr andre tilgang til datasentertjeneste mot vederlag, eller
- b. driver datasenter med en abonnert elektrisk effekt over en terskelverdi som fastsettes av departementet i forskrift. Dette inkluderer virksomhetsinterne datasentre, med unntak av forsvarssektoren, politiet og Politiets sikkerhetstjeneste

[Ekomloven § 1-2](#) . Saklig virkeområde

Loven gjelder virksomhet knyttet til elektronisk kommunikasjon og tilhørende utstyr og datasentre.

[Ekomloven § 1-3, andre ledd](#) . Geografiske virkeområde

Kongen kan gi forskrift om lovens anvendelse på Jan Mayen, Bouvetøya, Peter I øy og Dronning Maud Land. Kongen kan i forskrift fastsette de unntaks- og særregler som følger av internasjonale overenskomster som Norge har sluttet seg til, eller som er nødvendige på grunn av de stedlige forhold.

[Ekomloven § 1-5](#) . Definisjoner

I denne lov menes med:

- 36. datasenter: et anlegg, del av anlegg eller gruppe av anlegg som brukes for å innplassere, tilkoble og drifte IT- og nettverksutstyr for datalagring, dataprosessering eller dataoverføring, og relaterte aktiviteter.
- 37. datasentertjeneste: en tjeneste som legger til rette for innplassering, tilkobling og drift av IT- og nettverksutstyr for datalagring, dataprosessering og dataoverføring. Tjenesten omfatter i tillegg fysisk sikkerhet, strøm og kjøling og kan inkludere andre relaterte tjenester
- 38. datasenteroperatør: fysisk eller juridisk person som

-
- a. tilbyr andre tilgang til datasentertjeneste mot vederlag, eller
 - b. driver datasenter med en abonnert elektrisk effekt over en terskelverdi som fastsettes av departementet i forskrift. Dette inkluderer virksomhetsinterne datasentre, med unntak av forsvarssektoren, politiet og Politiets sikkerhetstjeneste.
-

1.3 Definisjoner

Om datasenter: Datasentre kan være av forskjellig karakter og størrelse. Datasenter kan spenne fra et enkelt datarom til en «hyperscale» datasenterinstallasjon som bruker flere hundre megawatt effekt (MW). Et datasent kan ha flere datasenteroperatører iht. § 1-5 nr. 38 bokstav a. dersom det er flere virksomheter hvis hovedforretningsmodell er å tilby datasentertjenester mot vederlag i anlegget.

Om datasentertjeneste: Datasentertjenester omfatter tjenester som tilbys med utgangspunkt i et fysisk datasenter. Dette inkluderer tjenester som legger til rette for innplassering, tilkobling og drift av IT- og nettverksutstyr. Andre relaterte tjenester knyttet til det fysiske datasenteret kan inkludere ytterligere tilgangskontroll og sikring, opplistingen er ikke uttømmende. Selve driften av IT og nettverksutstyret for datalagring, dataprosessering og dataoverføring omfattes ikke av definisjonen. Dette medfører at andre digitale tjenester og skytjenester ikke omfattes.

Om datasenteroperatør:

- Datasenteroperatør: § 1-5 nr. 38. Etter bokstav a omfattes aktører som tilbyr andre tilgang til en datasentertjeneste mot vederlag. Dette gjelder uavhengig av om aktøren eier det fysiske datasenteranlegget selv, eller opererer med utgangspunkt i et leieforhold i for eksempel et «co-location»-datasenter. Når kommersielle datasentre nevnes, betyr dette en aktør som tilbyr andre tilgang til datasentertjeneste mot vederlag

Etter bokstav b omfatter definisjonen også fysiske eller juridiske personer som driver eller leier datasenter, inkludert til egen virksomhet, med en abonnert elektrisk effekt som fastsettes av departementet i forskrift.

Formålet med denne avgrensningen er å sikre at reguleringen treffer de viktigste aktørene som opererer i datasenter og datasentertjenester av en slik størrelse og omfang at de antas å ha en betydelig samfunnskritisk betydning, mens mindre aktører ikke omfattes. Eventuelle datasenteroperatører som administrerer og opererer flere mindre datasentre som i sum overstiger terskelverdien for abonnert effekt, vil likevel omfattes. Dette innebærer at det kan være flere pliktsubjekter i ett og samme fysiske datasenteranlegg. For eksempel kan et større «co-location» datasenter ha leietakere som bruker leid areal/tjenester som utgangspunkt til selv å tilby datasentertjenester til andre, og leietakere som installerer og driver datasenter til egen virksomhet med en elektrisk effekt over terskelverdien. Både eieren av «co-location» datasenteret, og de to nevnte leietakerne vil da omfattes av definisjonen av datasenteroperatør. Definisjonen vil også omfatte dedikerte datasentre for kryptovalutautvinning. Datasenter som opereres av forsvarssektoren og politiet, inklusive Politiets sikkerhetstjeneste, er unntatt. Av hensyn til klarhet, nevnes Politiets sikkerhetstjeneste særskilt i unntaket. Loven legger ikke føringer på tolkningen av andre lover der politiet omtales generelt uten at Politiets sikkerhetstjeneste nevnes særskilt.

Datasenterforskriften § 1-2. Terskelverdi for datasenteroperatør

Terskelverdien etter ekomloven § 1-5 nr. 38 bokstav b er 0,5 MW.

Med abonnert elektrisk effekt menes det som tildeles av lovlig elektrisk effekt fra kraftnettet til et datasenter. Tildelingsansvaret ligger under Norges vassdrags- og energidirektorat (NVE), som gir tillatelser til et definert effektforbruk gjennom konsesjoner.

Terskelverdien er absolutt og registreringsplikten inntreffer idet et datasenter overstiger denne terskelverdien.

2 Registreringsplikt i lov og forskrift

2.1 registreringsplikt i lov

Ekomloven § 3-7, første ledd

Datasenteroperatør har plikt til å registrere seg hos departementet før virksomheten starter opp. Virksomheten kan settes i gang når registreringen er gjennomført.

Selv om det kun er enkelte bestemmelser i ekomloven som gjelder for datasentre – blant annet § 1-1 om lovens formål, § 3-7 om beredskap og prioritering, samt deler av kapittel 14–17 – fremgår det at forsvarlig sikkerhet i datasentre er en del av lovens formål.

2.2 krav til registrering i forskrift

Datasenterforskriften § 1-3, første og annet ledd. Registreringsplikt for datasenteroperatører

En datasenteroperatør skal registrere seg hos Nasjonal kommunikasjonsmyndighet før virksomheten starter opp. Virksomheten kan settes i gang når registrering er sendt.

Registreringen skal inneholde

1. datasenteroperatørs navn
2. norsk organisasjonsnummer eller datasenteroperatørens rettslige status, form og registreringsnummer dersom datasenteroperatøren er registrert i et handelsregister eller et lignende offentlig register i EØS
3. norsk adresse eller adressen til datasenteroperatørens eventuelle hovedforetak i EØS og eventuelt en sekundær filial
4. datasenteroperatørens nettsadresse
5. datasentrenes fysiske lokasjon
6. kontaktinformasjonen til en representant for datasenteroperatøren som kan møte opp fysisk med fullmakter og kunnskap til å kunne følge opp henvendelser fra myndighetene
7. en beskrivelse av hvilke tjenester som tilbys

8. informasjon om norske statlige, fylkeskommunale og kommunale myndigheter, organer og virksomheter som er kunder hos datasenteroperatøren
 9. anslag over prosentvis andel av kraftforbruket som skal anvendes til utvinning av kryptovaluta
 10. opplysninger om størrelsen på abonnert elektrisk effekt
 11. forventet oppstart av virksomheten
-

[Datasenterforskriften § 1-3](#) presiserer hvilke opplysninger det er datasenteroperatør skal registrere. Dette inkluderer både informasjon om datasenteroperatøren (den juridiske enheten) og datasentrene operatøren drifter eller planlegger å starte opp.

På [Nkoms nettside](#) for registreringen er det gitt nærmere veiledning om registreringen. Virksomheten må i forbindelse med registreringen gjennom en verifisering for å påvise at representanten som gjennomfører registreringen tilhører virksomheten. Virksomheter som krever at to eller flere representanter signerer på vegne av virksomheten må ta kontakt med Nkom for hjelp i prosessen, da den digitale løsningen foreløpig ikke støtter at flere representanter signerer.

Dersom virksomheten skal registrere opplysninger som ikke kan registreres gjennom registreringsskjemaet, f.eks fordi opplysningene ikke kan registreres på en ugradert plattform, må virksomheten ta kontakt med Nkom.

Datasenterforskriften § 1-3, fjerde ledd. Registreringsplikt for datasenteroperatører

Nasjonal kommunikasjonsmyndighet kan pålegge datasenteroperatører som faller under terskelverdien, men som er av særlig viktighet, å registrere seg. Nasjonal kommunikasjonsmyndighet kan ved enkeltvedtak gi unntak fra registreringsplikten i tilfeller der registrering er unødvendig for å oppfylle formålet med registreringen.

Myndighetene har behov for å få en oversikt over datasentre, inkludert datasentre som utvinner kryptovaluta. Dette vil sikre oversikt over hvem som tilbyr datasentertjenester, herunder kontaktinformasjon til personer som er ansvarlig for datasenteroperatøren og datasenteroperatørens virksomhet. Registreringsplikten er og nødvendig for at Nkom skal kunne følge opp datasenteraktørene gjennom tilsyn. Det understrekes at registreringsplikten ikke innebærer en tillatelse eller godkjennelsesordning fra myndighetenes side, men er en ren registreringsplikt. Det vil si at man ikke trenger å vente på en tilbakemelding fra myndighetene før virksomheten starter opp, så lenge man har registrert seg.

I særskilte tilfeller kan Nkom pålegge datasenteroperatører som har virksomhetsinterne datasentre med en abonnert elektrisk effekt under 0,5 MW å registrere seg. Likeledes kan myndigheten gi unntak fra registreringsplikten der det vurderes som formålstjenlig. Dette er først og fremst ment som en sikkerhetsventil for å unngå urimelige resultater, og eventuelt også klargjøre grensene for registreringsplikten dersom det skulle behov for dette

3 Sikkerhet og beredskap

3.1 krav til sikkerhet i ekomloven

Ekomloven § 3-7, andre og tredje ledd

Datasenteroperatør skal tilby og opprettholde datasentertjenester med forsvarlig sikkerhet for brukerne i fred, krise og krig. Datasenteroperatør skal opprettholde forsvarlig beredskap, og viktige samfunnsaktører skal prioriteres ved behov. Departementet kan fatte enkeltvedtak for å sikre at datasenteroperatør gjennomfører tiltak som gir forsvarlig sikkerhet og beredskap. Datasenteroperatør skal dekke kostnadene ved oppfyllelsen av dette.

Datasenteroperatør skal systematisk følge opp sikkerhet og beredskap i datasentertjenesten, og skal dokumentere et forsvarlig sikkerhetsnivå. Ved vurderingen av hva som er forsvarlig, vektlegges evnen til å motstå enhver hendelse som medfører eller kan medføre brudd på tilgjengelighet, autentisitet, integritet eller konfidensialitet i datasentertjenester. Det skal blant annet tas hensyn til beste tilgjengelige tekniske løsning, anerkjente standarder, tiltakenes kostnad og nytteverdi, og datasentertjenestens betydning.

Bestemmelsens *andre ledd* stiller krav til forsvarlig sikkerhet i datasenter og er utformet med utgangspunkt i de samme forpliktelsene som stilles til sikkerhet i elektronisk kommunikasjonsnett og -tjenester, jf. lovforslaget § 3. Det vil si at datasenter og tjenester skal være tilgjengelig og at integriteten, autentisiteten og konfidensialiteten skal beskyttes. Det er datasenteroperatørs ansvar at tjenestene som tilbys holder et forsvarlighetsnivå. *Andre ledd annet punktum* stiller krav til at datasenteroperatør skal opprettholde forsvarlig beredskap i datasenter og tjenester. Kravet til forsvarlig beredskap innebærer blant annet at datasenteroperatør skal treffe alle nødvendig tiltak som er forholdsmessig for å sikre størst mulig tilgjengelighet i tilfelle av force majeure hendelser. *Andre ledd tredje punktum* gir departementet kompetanse til å treffe enkeltvedtak for å sikre at datasenteroperatør iverksetter nødvendige tiltak for å sikre forsvarlig sikkerhet. Dette kan blant annet gjelde krav om separasjon av kunder eller kundegrupper når dette er nødvendig. Det stilles krav om at eventuelle kostnader ved vedtak etter *andre ledd* dekkes av datasenteroperatør.

Tredje ledd inneholder krav om systematisk oppfølging av sikkerhet og beredskap, krav til dokumentasjon av sikkerhetsmessige vurderinger, samt presisering av hvilke momenter som skal vektlegges i vurderingen av om sikkerhetsnivået er forsvarlig, men som ikke er uttømmende. Datasenteroperatør skal vurdere kompenserende tiltak dersom den valgte tekniske løsningen som systemet bygger på inneholder kjente svakheter, jf. *tredje ledd annet punktum*. Kravet skjerpes jo viktigere tjenester datasenteret bærer, men kravet om forholdsmessighet etter [forvaltningsloven](#) vil gjelde også på dette området.

Krav til sikkerhet og beredskap utdypes i kapittel 2 i datasenterforskriften.

Ekomloven § 3-8, første, andre, sjette, åttende og niende ledd. Tillatte bruksbegrensninger

Departementet kan, av hensyn til nasjonal sikkerhet eller andre viktige samfunnsinteresser, pålegge tilbyder eller datasenteroperatør å gjennomføre bruksbegrensning i elektroniske kommunikasjonsnett og -tjenester eller

datasentertjeneste. Departementet skal notisere bruksbegrensninger i elektroniske kommunikasjonsnett og -tjenester til EFTAs overvåkningsorgan.

Tilbyder og datasenteroperatør skal gjennomføre nødvendige bruksbegrensninger i nødssituasjoner som innebærer alvorlige trusler mot liv eller helse, nasjonal sikkerhet eller offentlig orden, eller fare for sabotasje mot datasenter, nett eller tjeneste.

I andre tilfeller enn nevnt i andre, tredje og femte ledd krever gjennomføring av bruksbegrensning tillatelse fra departementet.

Bruksbegrensning etter andre ledd skal avbrytes så snart nødssituasjonen er over, og etter tredje og fjerde ledd så snart sluttbruker godtgjør at nødvendig tillatelse foreligger eller ulovlig radio- og terminalutstyr er frakoblet nettet.

Departementet kan gi forskrift om bruksbegrensninger og om unntak fra kravet om tillatelse til bruksbegrensninger.

Bestemmelsen regulerer tilbyders adgang til å gjennomføre bruksbegrensninger i elektroniske kommunikasjonsnett og -tjenester og gir departementet kompetanse til å pålegge tilbyder å gjennomføre nødvendige bruksbegrensninger. Formålet med bestemmelsen er å sikre kontinuitet i brukerens elektroniske kommunikasjon og at bruksbegrensningene som foretas er nødvendige og forholdsmessige. Også for datasenteroperatør kan det oppstå et behov for å tillate bruksbegrensning, og bestemmelsen er derfor også gjeldende for datasenteroperatør og datasentertjeneste.

Ekodirektivet artikkel 12 nr. 1 åpner for at nasjonalstaten kan gi regler om begrensninger i adgangen til å tilby elektroniske kommunikasjonsnett og -tjenester når dette er nødvendig av grunner som følger av traktaten om den europeiske unions virkemåte (TEUV) artikkel 52 nr. 1 (liv eller helse, nasjonal sikkerhet eller offentlig orden). Ekodirektivet artikkel 40 og 41 gir regler om sikkerhet i nett og tjenester, og artikkel 45 nr. 4 fastslår at staten kan fastsette rimelige begrensninger i teknologibruken blant annet når det er nødvendig for å unngå skadelig interferens og sikre tjenestenes tekniske kvalitet.

Første ledd gir departementet kompetanse til å gi tilbyder og datasenteroperatør pålegg om å gjennomføre bruksbegrensninger. Slike pålegg kan gis av hensyn til nasjonal sikkerhet og andre viktige samfunnsinteresser, og skal være godt begrunnet. Departementet må ta hensyn til at sluttbruker ved bruksbegrensninger vil kunne bli stående uten kommunikasjonstjenester eller datasentertjenester i en mellomperiode. Det er med andre ord en viss terskel for å pålegge bruksbegrensninger. Første ledd legger opp til at departementet skal forta en konkret vurdering i det enkelte tilfellet. Pålegg etter første ledd skal begrunnes, og pålegg om bruksbegrensninger skal notiseres til EFTAs overvåkningsorgan.

Andre ledd pålegger tilbyder og datasenteroperatør å gjennomføre nødvendige bruksbegrensninger i nødssituasjoner. Når det gjelder de opplistede nødssituasjonene som gir tilbyder eller datasenteroperatør plikt til å innføre bruksbegrensninger, forutsettes det at tilbyder eller datasenteroperatør selv tar stilling til om det foreligger fare for sabotasje mot nett eller tjenester. Når det gjelder alvorlige trusler mot liv eller helse så kan tilbyder eller datasenteroperatør selv ta stilling til dette, eller det kan skje i samarbeid med myndigheter. Tilbyder eller datasenteroperatør kan også ta selvstendig stilling til åpenbare tilfeller av trusler mot nasjonal sikkerhet eller

offentlig orden, men det vil i de fleste tilfeller være praktisk for tilbyder eller datasenteroperatør å foreta bruksbegrensninger som skyldes slike forhold i samråd med departementet.

Det følger av sjette ledd at gjennomføring av bruksbegrensning i andre tilfeller enn angitt i andre, tredje og fem ledd, krever tillatelse fra departementet. Bakgrunnen for kravet om tillatelse er konkurransehensyn.

Plikten til å avbryte bruksbegrensningen etter andre ledd så snart nødsituasjonen er over følger av åttende ledd

I niende ledd innføres hjemmel til å fastsette forskrift om bruksbegrensninger og tillatelse fra departementet.

Ekomloven § 3-9. Krav om politiattest

Tilbyder av elektroniske kommunikasjonsnett og -tjenester og datasenteroperatør kan kreve at personer fremlegger uttømmende og utvidet politiattest, jf. [politiregisterloven § 41](#) . Politiattest kan kreves for den som har fått tilbud om eller er innstilt til en stilling, og som skal ha tilgang til elektroniske kommunikasjonsnett, tilhørende fasiliteter, datasentre, utstyr, systemer eller informasjon som er av vesentlig betydning for sikkerheten i nett eller tjenester, er taushetsbelagt, eller som av annen grunn er av særlig sensitiv karakter. Slik politiattest kan også kreves for ansatte hos leverandører. Politiattesten skal ikke være eldre enn 90 dager ved fremvisning. Det kreves ikke politiattest for personer som innehar gyldig sikkerhetsklarering eller adgangsklarering etter [sikkerhetsloven](#) .

Departementet kan gi forskrift om fremleggelse av politiattest, herunder om hvilke lovbrudd politiattesten skal vise.

Bestemmelsen er ny og er basert på nasjonale behov. Første ledd gir tilbyder av elektronisk kommunikasjonsnett og tjenester og datasenteroperatør mulighet til å stille krav om uttømmende og utvidet politiattest. Hva som skal anses som uttømmende og utvidet politiattest følger av [politiregisterloven § 41](#) . Muligheten for innhentir og fremlegges av politiattest gjelder ved nyansettelser. Kravet om politiattest kan ikke gis tilbakevirkende kraft og således ikke kreves fremlagt av personer som allerede er ansatt. Imidlertid er det mulig å kreve politiattest av allerede ansatt personell dersom vedkommende får nye eller endrede oppgaver som medfører et berettiget behov for politiattest.

Krav om politiattest kan være et viktig sikkerhetstiltak for personer som skal ha tilgang til elektroniske kommunikasjonsnett, tilhørende fasiliteter, datasenter, utstyr, systemer eller informasjon, med vesentlig betydning for sikkerheten i nett og tjenester eller som av en annen grunn er av særlig sensitiv karakter. Det kan også kreves fremlagt politiattest for personell hos tilbyderes eller datasenteroperatørs leverandør. Med vesentli betydning menes at det som skal vernes må være av særlig viktighet for offentlig elektroniske kommunikasjonstjenester, jf. blant annet [klassifiseringsforskrifta § 4](#) . Dette kan for eksempel være nettutstyr som er kritisk for samtrafikk med elektroniske kommunikasjonsnett i eller utenfor landet eller sensitiv informasjon som for eksempel kundelister, trafikkdata og lignende. Krav om politiattest vil bare være hensiktsmessig for særlige grupper av ansatte etter en konkret vurdering. Denne vurderingen vil bero på en risikovurdering om hva som kan føre til betydelige skadevirkninger. Virksomheten må foreta en konkret vurdering av muligheten for å utnytte tilgang til informasjon og eller infrastruktur etc. i skadeøymed og skadeomfanget dette vil kunne medføre. Begrepet «tilgang» innbefatter både logisk og fysisk tilgang.

Om en person skal kunne anses for uegnet for en stilling eller oppgave vil bero på en vurdering av flere forhold, hvor også betydningen av tilgang til ulike systemer eller informasjon må inngå i vurderingen. Departementet bemerker at det normalt ikke vil være krav om plettfriandel, og at det således normalt bør ses bort fra forhold av bagatellmessig art. Videre vil for eksempel forbrytelser mot statens selvstendighet og sikkerhet, terrorhandlinger, terrorrelaterte handlinger, korrupsjon og annen vinningskriminalitet være forhold av særlig betydning for vandelsvurderingen. Graverende tilfeller vil kunne få betydning selv om det er gått lang tid siden forholdet ble begått. Det kan også tenkes forhold som er så alvorlige at vedkommende må anses å ha en slik personlighetsbrist at vedkommende finnes varig uskikket. Departementet presiserer at dette ikke er en uttømmende liste over forhold som vil kunne vektlegges i vurderingen, men at også andre forhold vil kunne få betydning.

Departementet legger til grunn at tilbyder og datasenteroperatør vurderer om andre sikkerhetstiltak kan komme til anvendelse før det kreves fremlagt politiattest.

Det følger av andre ledd at dersom vedkommende er sikkerhetsklarert eller innehar adgangsklarering fra Sivil klareringsmyndighet, vil det ikke stilles krav om politiattest. Bakgrunnen for dette er at den som er sikkerhetsklarert eller som har adgangsklarering etter sikkerhetsloven, allerede har vært gjennom en mer omfattende personkontroll enn den som gjøres ved utstedelse av politiattest.

I tredje ledd gis departementet kompetanse til å gi nærmere bestemmelser om fremleggelse av politiattest. Ytterligere avgrensning av når politiattest kan kreves kan således gjøres i forskrift.

3.2 Krav til sikkerhet i datasenterforskriften

Datasenterforskriften § 2-1. Krav til sikkerhetsstyring

En datasenteroperatør skal etablere og vedlikeholde et styringssystem for sikkerhet som beskriver virksomhetens sikkerhetsarbeid. Systemet skal sikre at virksomheten oppfyller krav gitt i eller med hjemmel i lov.

Virksomhetens leder skal jevnlig foreta en gjennomgang av virksomhetens styringssystem for sikkerhet.

Styringssystemet skal gjøres kjent for virksomhetens ansatte og underleverandører i den grad det er hensiktsmessig for å oppfylle krav gitt i eller med hjemmel i lov.

Datasenteroperatørens styringssystem for sikkerhet skal dokumenteres.

Datasenteroperatøren skal jevnlig kontrollere og revidere planverk og dokumentasjon knyttet til virksomhetens sikkerhetsstyring for å sikre at krav fastsatt i eller med hjemmel i lov er oppfylt.

Kravet til sikkerhetsstyring er i likhet med forsvarlig sikkerhet et funksjonelt krav. Det at kravet er funksjonelt betyr at det bevist ikke stilles klare detaljkrav til sikkerhet, dette er for at kravene til sikkerhet skal kunne følge den teknologiske utviklingen og samtidig være førende innenfor kravet om forsvarlig sikkerhet.

Kravet om sikkerhetsstyring utdyper lovens krav om systematisk oppfølging av sikkerhet i datasenter, og innebærer at virksomheten skal ha et dokumentert styringssystem. Styringssystemet må etableres for den konkrete virksomheten, det er ikke tilstrekkelig at f.eks. et moderselskap har etablert et sikkerhetssystem.

Med sikkerhetsstyring menes et styringssystem for sikkerhet. Et slikt styringssystem for sikkerhet innebærer systematiske aktiviteter med betydning for forebyggende sikkerhetsarbeid, og omfatter planlegging, etablering, gjennomføring og forbedring av det forebyggende sikkerhetsarbeidet. Dette er nødvendig for å oppnå og opprettholde forsvarlig sikkerhet i nett og tjenester. Styringssystemet kan f.eks. etableres med grunnlag i anerkjente standarder for styring som ISO 9000-serien og ISO 27000-serien. Forutsetningen er at styringssystemet dekker hele det forebyggende sikkerhetsarbeidet.

Et styringssystem for sikkerhet innebærer systematiske aktiviteter med betydning for det forebyggende sikkerhetsarbeidet, og omfatter temaer som planlegging, etablering, gjennomføring og forbedring, hendelseshåndtering og revisjon. Det er dermed nødvendig å ha alle disse forskjellige komponentene på plass for å oppnå og opprettholde et forsvarlig sikkerhetsnivå, basert på den risiko virksomheten er eksponert for. Departementet har i forarbeidene til det tilsvarende kravet i ekomforskriften presisert at følgende elementer vil utgjøre minstekrav i vurderingen av om forsvarlig sikkerhet og sikkerhetsstyring foreligger:

- Ledelsesforankring
- Verdivurdering
- Risikovurdering
- Tiltak og handlingsplaner for å beskytte verdier
- Beredskapsplanlegging og øvelser
- Revisjon
- Overholdelse av oppfølgingsplikten
- Informasjonssikkerhet
- Dokumentasjon

Et styringssystem for sikkerhet bidrar til å beskytte virksomhetens viktige verdier, videre vil det føre til en kontinuerlig forbedring og utvikling i arbeidet med forebyggende sikkerhet, gitt den risikoen virksomheten er vill til å ta. Et styringssystem handler om hvordan virksomheten arbeider med sikkerhet, i tillegg til å beskrive hvordan virksomheten styrer og utfører tiltak og aktivitetene sine.

Forebyggende sikkerhetsarbeid starter med en verdivurdering der virksomheten kartlegger sine verdier. En slik verdivurdering er en forutsetning for riktig prioritering av ressurser virksomheten har til rådighet for sikkerhet, og for å kunne gjennomføre effektive sikringstiltak. Verdivurderinger må dokumenteres, jf. kravet i bestemmelsens tredje ledd. Tilsvarende krav til gjennomføring av verdivurdering er gitt i sikkerhetsloven og virksomhetsikkerhetsforskriften kapittel 3. Det følger av bestemmelsens første ledd annet punktum at systemet skal sikre at virksomheten oppfyller krav gitt i eller med hjemmel i lov. Her siktes det til krav gitt i ekomloven eller andre relevante lover f.eks. personopplysningsloven når det gjelder sikring av personopplysninger, samt til forskriftshjemmelen i ekomloven § 3-8.

Gjennom systematisk arbeid vil ledelsen i virksomheten få jevnlige orienteringer om sikkerhetstilstanden, og på den måten har ledelsen en evne til å ta avgjørelser basert på et mer informert grunnlag. Sikkerhetsstyring bidrar dermed til proaktivt fremfor reaktiv styring. Det setter virksomheten i stand til å forebygge hendelser, i stedet for å måtte reagere etter at en uønsket hendelse har funnet sted.

Etter bestemmelsens annet ledd første punktum skal virksomhetens leder jevnlig foreta en gjennomgang av virksomhetens styringssystem for sikkerhet. Forebyggende sikkerhetsarbeid skal gjennomgås av virksomhetens leder. Denne skal gjøre prioriteringer og avsette nødvendige ressurser til arbeidet med den forebyggende sikkerheten. Som en del av forankringen hos virksomhetens leder må det utarbeides sikkerhetsmål, gjerne en sikkerhetsstrategi, og et styringsdokument. Leders evaluering bør formaliseres som et møte og dokumenteres skriftlig. Lignende krav til ledelsesforankring er gitt i [virksomhetsikkerhetsforskriften § 10](#) og finnes gjennomgående i standarden NS-EN ISO 9001:2015. Arbeidet med sikkerhet er en kontinuerlig prosess, jf. at virksomhetens leder jevnlig skal gjennomgå sikkerhetsstyringen. Dette innebærer bl.a. at lederen minst én gang årlig må gjennomgå sikkerhetsmål, sikkerhetsstrategi, organisering og vurderinger. Lederen skal kontrollere at disse er i samsvar med virksomhetens behov og eventuelt oppdatere dokumentene. Gjennomgangen bør utføres etter rutinebeskrivelse.

Etter bestemmelsens annet ledd annet punktum skal styringssystemet gjøres kjent for virksomhetens ansatte. Dette kan f.eks. gjøres i form av sikkerhetsinstruks, taushetserklæring, rutiner og sjekklister, og opplæring. Styringssystemet skal også gjøres kjent for underleverandører i den grad det er hensiktsmessig for å oppfylle krav gitt i eller med hjemmel i lov. Departementet viser i denne forbindelse til at virksomheten har ansvaret for oppfyllelse av plikter gitt i lov eller i medhold av lov også der deler av virksomheten er tjenesteutsatt/utkontraktert. Det bør derfor foreligge en skriftlig avtale som sikrer dette.

Etter bestemmelsens tredje ledd skal tilbyders styringssystem for sikkerhet dokumenteres fortløpende. Kravet til dokumentasjon innebærer et krav til skriftlighet. Dokumentene skal oppbevares hos tilbyder/datasenteroperatør.

Etter bestemmelsens fjerde ledd skal tilbyder jevnlig kontrollere og revidere planverk og dokumentasjon knyttet til virksomhetens sikkerhetsstyring for å sikre at krav fastsatt i eller med hjemmel i lov er oppfylt.

Datasenterforskriften § 2-2. Krav om risiko- og sårbarhetsvurdering

En datasenteroperatør skal utarbeide og vedlikeholde risiko- og sårbarhetsvurderinger for å ivareta forsvarlig sikkerhet i datasenteret. Risiko- og sårbarhetsvurderingene skal være av et slikt omfang at virksomheten kan identifisere organisatoriske, fysiske, logiske og menneskelige sikkerhetstiltak.

Ved endringer som kan påvirke sikkerheten skal datasenteroperatøren vurdere hvilken risiko endringene medfører.

Datasenteroperatørens risiko- og sårbarhetsvurderinger skal dokumenteres.

Risiko- og sårbarhetsvurdering (ROS) er en sentral del i virksomhetens sikkerhetsstyring og inngår derfor følgelig arbeidet med risikostyring. Her er målet å styre virksomhetens sikkerhetsarbeid for å oppnå et forsvarlig sikkerhetsnivå med utgangspunkt i den risikoen virksomheten eksponeres for. ROS-analysen har oppgaven å kartlegge og vurdere risikoen knyttet til virksomhetens drift på et overordnet nivå, oppnå god risikoforståelse og gi et underlag for valg av tiltak som må på plass for at risikoen til virksomheten skal være på et akseptabelt nivå. En ROS skal derfor kunne identifisere uønskede hendelser som kan inntreffe, sannsynligheten for at hendelsen kan inntreffe, vurdering av risiko og sårbarheter knyttet til hendelsen og utarbeide tiltak basert på ROS. Forståelse av risiko er viktig for at virksomheten skal kunne utforme en god ROS.

Virksomheten kan ikke velge å la være å utarbeide og vedlikeholde ROS, jf. ordlyden skal. ROS skal utarbeides og vedlikeholdes for den konkrete virksomheten, det er således ikke tilstrekkelig å vise til at moderkonsernet eller et søsterselskap har etablert slike.

En ROS analyse vil først kartlegge hvilke verdier som må sikres. Den bør inneholde en trusselvurdering som ser på hvilke trusselaktører som kan være interessert i virksomhetens verdier og hvilke potensielle angrepsvektorer slik trusselaktører benytter. Videre må det vurderes om verdiene er sårbare for truslene som identifiseres.

Resultatet av ROS-analysen som blir utviklet må vurderes opp mot et toleransenivå for sikkerhet. Altså, hvor stor risiko en skal ta ved ulike scenarioer. Risikoen må ligge innenfor forsvarlighetskravet i loven. Dersom risikonivået er høyere enn fastlagt nivå for akseptabel risiko, skal det iverksettes tiltak for å redusere risikoen. Det er virksomhetens leder som avgjør toleransenivået for sikkerhet. I operasjonaliseringen av kravet til forsvarlig sikkerhet legges god ledelsesforankring til grunn som et av flere minstekrav i vurderingen av forsvarlig sikkerhet.

Det følger av første ledd annet punktum at ROS skal være av et slikt omfang at tilbyder kan identifisere organisatoriske, fysiske, logiske og menneskelige sikkerhetstiltak. Med ordlyden av et slikt omfang menes at ROS både skal omfatte tilstrekkelig kvantitative og kvalitative vurderinger.

Eksempler på organisatoriske tiltak kan være prosedyrer, sikkerhetsstrategier, rutiner og opplæring m.m. Fysiske sikkerhetstiltak skal hindre eller forsinke uønsket adgang til verdier, slike tiltak kan være tidsforsinkende barrierer som gjerder, porter, dører, adgangskontroll m.m. Logiske sikkerhetstiltak kan være konfigurering av elektroniske systemer, kryptering og tilgangsstyring basert på tjenstlige behov, ved bruk av passord, autentisering, tilgangsnivå og brukerroller. Videre er gode logg systemer svært viktige for blant annet logging av personell får et godt oversiktsbilde av hvem som bruker og har tilgang til systemer, også nettverksbasert logging for oversikt av autorisert og uautorisert bruk, drift og endringer av systemer m.m. Eksempler på menneskelige sikkerhetstiltak kompetanse, kultur, taushetserklæringer, fullmakt og klarering.

Etter bestemmelsens annet ledd skal tilbyder ved endringer som kan påvirke sikkerheten vurdere hvilken risiko endringene medfører. Bestemmelsen angir ikke størrelse eller karakter på endringen, bare at det må påvirke sikkerhetsarbeidet. I så fall må tilbyder vurdere hvilken risiko endringene medfører.

Etter bestemmelsens tredje ledd skal tilbyders risiko- og sårbarhetsvurderinger dokumenteres fortløpende. Kravet til dokumentasjon innebærer et krav til skriftlighet. Dokumentene skal oppbevares hos virksomheten.

Datasenterforskriften § 2-3. Krav til grunnsikring og skadebegrensningstiltak

En datasenteroperatør skal utarbeide, iverksette og vedlikeholde grunnsikringstiltak for å ivareta forsvarlig sikkerhet i datasenteret. Grunnsikringstiltak innebærer en kombinasjon av barrierer, deteksjons-, verifikasjons- og reaksjonstiltak.

Datasenteroperatøren skal planlegge skadebegrensningstiltak som kan iverksettes i situasjoner som ikke kan håndteres fullt ut med grunnsikringstiltakene.

Datasenteroperatøren skal ha en plan for å gjenopprette et forsvarlig sikkerhetsnivå.

Tiltak som nevnt i første og andre ledd, samt planer som nevnt i tredje ledd, skal dokumenteres.

Etter første ledd skal datasenteroperatør utarbeide, iverksette og vedlikeholde grunnsikringstiltak for å ivareta forsvarlig sikkerhet. Virksomheten kan ikke velge å la være å utarbeide, iverksette og vedlikeholde grunnsikringstiltak, jf. ordlyden skal.

Grunnsikring innebærer at sikkerhetstiltakene rundt verdiene i bygget eller på eiendommen er på plass og er i daglig drift, slik at tiltakene vil kunne håndtere en trussel som kan oppstå uten forvarsel. Dette gjelder både tilsiktede og utilsiktede hendelser. Grunnsikring omfatter tiltak innenfor fysisk- og elektronisk sikring, samt menneskelige og organisatoriske tiltak som kan håndtere mulige trussel scenarioer som kan oppstå. Grunnsikring må være til stede permanent, men det må i tillegg være planlagt ulike beredskapstiltak som kan forsterke sikringen ved behov.

Grunnsikringstiltak skal være med å bidra til et forsvarlig sikkerhetsnivå for virksomheter ved normaltilstand. Tiltak innenfor grunnsikring består blant annet av:

- Fysiske, elektroniske, menneskelige eller organisatoriske barrierer
- Systemer som skal oppdage og varsle om aktiviteter eller hendelser
- Systemer og rutiner for å avklare aktiviteter og hendelser og bakgrunnen for dem
- Oppfølging av uønskede aktiviteter og uønskede hendelser
- En kombinasjon av tiltakene ovenfor

En slik kombinasjon av barrierer, deteksjons-, verifikasjons og reaksjonstiltak må planlegges, gjennomføres og vedlikeholdes. Grunnsikringen er de etablerte, verifiserte og dokumenterte samlede sikkerhetstiltakene som skal beskytte virksomhetens verdier. Tiltakene som implementeres skal stå i sammenheng med virksomhetens risikovurdering. Virksomheten er pliktig til å utarbeide og vedlikeholde grunnsikringstiltak. Det betyr at tiltakene basert på risikovurderingene, blir revidert jevnlig, og skal derfor til enhver tid gjenspeile et «best practice» nivå.

Kravene til grunnsikringstiltak vil måtte tolkes strengere der det er tale om å tjenestestutsette deler av virksomhetens drift til leverandører/produsenter som ikke er hjemmehørende i Norge. I tillegg til å vurdere tjenesteleverandør, bør datasenteroperatøren vurdere vertslandet der leverandøren har tilhold og hvor tjenesteleverandøren tilbys fra. Nasjonale forhold kan påvirke en leverandørs mulighet til å levere tjenester, eksempelvis gjennom kvaliteten på nasjonal infrastruktur eller nasjonal lovgivning som gir rett til innsyn i data lagret i vertslandet. Risikoen knyttet til vertslandet kan dermed gi avgjørende føringer på behovet for kompenserende sikringstiltak og hvilke tjenstedatasenteroperatører som bør vurderes. Landvurderingen bør inngå som en del av den totale risikovurderingen ved tjenestestutsettingen. Kravene til tiltak vil måtte tilpasses trusselen det enkelte land utgjør eller vil kunne utgjøre i utstyrets levetid.

Tredje ledd innebærer krav til at datasenteroperatør skal ha en plan for gjenoppretting for å sikre forsvarlig sikkerhet og hindre unødige nedetid.

Datasenteroperatør skal planlegge skadebegrensende tiltak som kan iverksettes i situasjoner som ikke fullt ut kan håndteres med grunnsikringstiltakene. Dette kan for eksempel være tiltak for å oppnå redundans. Det stilles krav til at datasenteroperatør skal ha en plan for gjenoppretting for å sikre forsvarlig sikkerhet og hindre unødige nedetid.

Etter bestemmelsens fjerde ledd skal datasenteroperatørens tiltaksplaner dokumenteres. Kravet til dokumentasjon innebærer et krav til skriftlighet. Dokumentasjonen skal oppbevares hos virksomheten.

Datasenterforskriften § 2-4. Krav til sikringsplaner

En datasenteroperatør skal utarbeide, iverksette og vedlikeholde planer for sikring av informasjon, informasjonssystemer og styringssystemer. Slike sikringsplaner innebærer som et minimum at datasenteroperatøren utarbeider og iverksetter prosedyrer for tildeling av rettigheter, tilgangskontroll, endring, sletting, logging, redundans, sikkerhetskopiering, vedlikehold og testing for å ivareta tilgjengelighet, autentisitet, integritet og konfidensialitet.

Datasenteroperatørens sikringsplaner skal dokumenteres.

Styringssystem for sikkerhet handler om de systematiske aktivitetene som er nødvendige for å oppnå og opprettholde et forsvarlig sikkerhetsnivå for virksomheten og verdiene virksomheten disponerer. Sikkerhetsstyring omfatter alle aktiviteter med betydning for virksomhetens sikkerhetsarbeid og skal gjennomføres på en planlagt og systematisk måte i form av et sikkerhetsstyringssystem som omfatter planlegging, gjennomføring, kontrollering og forbedring av sikkerhetsarbeidet. Uten et styringssystem for sikkerhet undergraves virksomhetens evne til å gjennomføre og kontrollere sikkerhetsarbeidet på en planlagt og systematisk måte.

I henhold til første ledd skal datasenteroperatør utarbeide, iverksette og vedlikeholde konkrete planer for sikring av informasjon, informasjonssystemer og styringssystemer. Datasenteroperatør kan ikke velge å la være å utarbeide, iverksette og vedlikeholde sikringsplaner, jf. ordlyden skal. Planer for sikring skal utarbeides og vedlikeholdes for den konkrete virksomheten, det er således ikke tilstrekkelig å vise til at moderkonsernet eller et søsterselskap har utarbeidet slike.

Forskriften stiller krav til prosedyrer for tilgangsstyring som er metoder for å tildele, endre, slette og føre kontroll med autorisasjon for tilgang til IT-ressurser. Slik tilgangsstyring bør være basert på tjenstlig behov. Og kan i praksis gjennomføres gjennom bruk av eksempelvis passord, autentisering, tilgangsnivå og brukerroller. Utvikling, testing og opplæring bør separeres for å redusere risiko for uautorisert tilgang eller uønskede endringer. Videre er det viktig med gode rutiner for opprettelse og vedlikehold av brukere. Logging av autorisert og uautorisert bruk for drifts- og sikkerhetsformål (klientbasert logging) og nettverksbasert logging for å kunne oppdage datainnbrudd og virus vil være tiltak som innebærer å etterkontrollere informasjonssystemet. Sikring av informasjons- og styringssystemer innebærer krav til redundans for sentrale elementer i informasjons- og styringssystemer for å ivareta forsvarlig sikkerhet. Sikkerhetskopiering må anses for å være nødvendig for å sikre at ikke viktig informasjon går tapt. I denne sammenheng vises det til at sikkerhetskopiering også er i henhold til god bransjepraksis, jf. ISO 27001. Prosedyrer for vedlikehold og testing vil kunne gi grunnlag for å vurdere effektiviteten av sikkerhetstiltakene.

Hensikten med sikringsplaner er å sikre vedvarende tilgjengelighet, autentisitet, integritet og konfidensialitet i informasjonssystemer og styringssystemer, som ligger til grunn for datasenteroperatørens tjenester. Merk ordlyden i lovteksten (ekomloven § 3-7, tredje ledd); datasenteroperatør skal systematisk følge opp sikkerhet og beredskap i datasentertjenester, og skal dokumentere et forsvarlig sikkerhetsnivå. Ved vurderingen av hva som

forsvarlig, vektlegges evnen til å motstå enhver hendelse som medfører eller kan medføre brudd på tilgjengelighet, autentisitet, integritet eller konfidensialitet i datasentertjenester.

Tilgjengelighet innebærer at tjenester er tilgjengelige. Autentisitet betyr at kommunikasjon og data er opprinne og ekte. Integritet innebærer at kommunikasjon og data ikke blir endret utilsiktet eller av uvedkommende for å sikre fullstendighet, nøyaktighet og gyldighet. Med konfidensialitet menes at kommunikasjon og data ikke blir kjent for uvedkommende, men kun at den autoriserte får tilgang.

Etter bestemmelsens annet ledd skal datasenteroperatørs planer for sikring dokumenteres. Kravet til dokumentasjon innebærer et krav til skriftlighet. Dokumentasjonen skal oppbevares hos virksomheten.

Datasenterforskriften § 2-5. Krav om beredskapsplanlegging og -øvelser

En datasenteroperatør skal utarbeide og vedlikeholde beredskapsplaner for å ivareta forsvarlig sikkerhet i datasenteret.

Datasenteroperatørens beredskapsplaner skal dokumenteres.

Datasenteroperatøren skal jevnlig gjennomføre beredskapsøvelser med det innhold og omfang som er nødvendig for å vedlikeholde og utvikle virksomhetens kompetanse og evne til å håndtere uønskede hendelser.

Plan for gjennomføring av beredskapsøvelser skal dokumenteres.

Datasenteroperatøren skal på forespørsel delta i beredskapsøvelser arrangert av departementet eller Nasjonal kommunikasjonsmyndighet.

§ 2-5 krav om beredskapsplanlegging og -øvelser vektlegger virksomhetens evne for effektiv hendelseshåndtering og rask gjenoppretting av drift. Beredskapsplanene skal ha klare beskrivelser av hvordan virksomheten skal håndtere ulike typer uønskede hendelser. Eksempler på slike hendelser kan være teknisk svikt, brann, strømbrudd, sikkerhetsbrudd, dataangrep, ekstremvær, innsidere m.m. I tråd med virksomhetens styringssystemer, krav til sikkerhetsstyring og ROS vurderinger, skal virksomhetens beredskapsplaner være godt dokumenterte og tilpasset virksomhetens risiko og -sårbarhetsbilde.

Videre vektlegger § 2-5 at beredskapsplaner og gjennomføring av beredskapsøvelser skal dokumenteres skriftlig. Det vises til at dokumentasjonen spesifikt innebærer et krav til skriftlighet for å sikre notoritet. Det fremgår av tredje ledd at datasenteroperatør jevnlig skal gjennomføre beredskapsøvelser med det innhold og omfang som er nødvendig for å vedlikeholde og utvikle virksomhetens kompetanse og evne til å håndtere uønskede hendelser. Gjennom en slik pågående aktivitet vil virksomheten ha et oppdatert beredskapsplanverk som konkret er tilpasset virksomheten. Videre at virksomheten skal delta i beredskapsøvelser arrangert av myndigheten.

Datasenterforskriften § 2-6. Adgang til å pålegge sikkerhetsrevisjon

Nasjonal kommunikasjonsmyndighet kan pålegge en datasenteroperatør å foreta en sikkerhetsrevisjon av hele eller deler av virksomheten, når opplysninger som er innhentet eller tilsyn som er gjennomført, ikke er tilstrekkelig til å besvare nødvendige spørsmål om virksomhetens sikkerhet. Nasjonal kommunikasjonsmyndighet kan stille krav til sikkerhetsrevisjonen. Revisjonen skal foretas av en uavhengig, kvalifisert tredjepart, og resultatet av

revisjonen skal sendes Nasjonal kommunikasjonsmyndighet. Datasenteroperatøren skal dekke alle kostnadene ved revisjonen.

Nkom kan med hjemmel i datasenterforskriften § 2-6 i særlige tilfeller pålegge datasenteroperatør å foreta en sikkerhetsrevisjon av hele eller deler av virksomheten. En sikkerhetsrevisjon vil kunne være aktuelt der myndigheten allerede har innhentet opplysninger eller gjennomført stedlig tilsyn, men hvor dette ikke har vært tilstrekkelig for å fullstendig besvare nødvendige spørsmål om virksomhetens sikkerhet. Ordlyden "særlige tilfelle" er valgt for å poengtere at sikkerhetsrevisjon ikke skal ilegges regelmessig eller erstatte myndighetens eget tilsyn.

Sikkerhetsrevisjonen kan bli pålagt for hele eller deler av virksomheten, f.eks. for deler av virksomheten som trenger ytterligere granskning eller som er spesielt sårbare. Et eksempel på dette kan være behov for å teste sikkerheten til internettilgang til viktige fasiliteter.

Paragrafens tredje punktum presiserer at revisjonen skal foretas av en uavhengig, kvalifisert tredjepart, og resultatet av revisjonen skal sendes Nkom. Med uavhengig, kvalifisert tredjepart, legger departementet opp til det utførende revisjonsfirmaet ikke på noen måte er nært forbundet med datasenteroperatøren. Virksomheter med sertifisering innen revisjon vil fylle vilkåret om kvalifisert, men også andre kan være kvalifisert, eksempelvis en offentlig myndighet. Det forutsettes at revisjonsrapporten sendes Nkom så snart den foreligger.

Datasenteroperatøren skal dekke alle kostnadene ved en revisjon. Dette omfatter både direkte og indirekte kostnader.

Datasenterforskriften § 2-7. *Plikt til å følge opp at andre oppfyller sikkerhetskravene*

En datasenteroperatør skal følge opp at leverandører, entreprenører og andre som utfører arbeid for eller på vegne av operatøren, etterlever sikkerhetskrav fastsatt i eller med hjemmel i lov.

Bestemmelsen pålegger datasenteroperatør å følge opp at leverandører, entreprenører og andre kontraktører som utfører arbeid på virksomheten vegne, herunder leverandører, entreprenører og andre kontraktører, etterlever sikkerhetskrav fastsatt i eller med hjemmel i lov. Dette gjelder også ved tjenesteutsetting utenfor Norge. Dette gjelder også kontraktører og underleverandører som driver sin virksomhet i Norge og som leverer tjenester til virksomheten.

Datasenteroperatøren har således en plikt til å følge opp sikkerhet gjennom hele verdikjeden når det settes arbeid ut på oppdrag.

Datasenterforskriften § 2-8. *Plikt til å varsle om uønskede hendelser*

En datasenteroperatør skal uten ugrunnet opphold varsle Nasjonal kommunikasjonsmyndighet om hendelser som har medført vesentlige brudd på datasenteret eller datasentertjenestenes tilgjengelighet, autentisitet, integritet eller konfidensialitet.

Varslet skal minst opplyse om hendelsens årsak, konsekvensene for datasenteret og datasentertjenestene, innvirkningen på økonomiske og samfunnsmessige aktiviteter, antallet berørte kunder og det geografiske omfanget i den grad opplysningene er kjent. Det skal også opplyses om tiltakene for å stoppe og utbedre skadene, og hvor lenge tjenestene har vært eller vil være påvirket av hendelsen.

Ved konkrete og betydelige trusler med fare for brudd på autentisitet, integritet eller konfidensialitet skal datasenteroperatør varsle kundene om mulige vernetiltak eller avhjelpende tiltak som kunden kan sette i verk. Vil det det være hensiktsmessig, skal datasenteroperatør også informere om selve trusselen.

En datasenteroperatør skal varsle kundene om planlagt arbeid som kan få konsekvenser for datasentertjenestene som tilbys.

Nasjonal kommunikasjonsmyndighet kan gi forskrift om nærmere prosedyrer for varsling.

Datasenteroperatøren plikter å varsle Nkom uten ugrunnet opphold om hendelser som har medført vesentlig brudd på datasenteret eller datasentertjenestens tilgjengelighet, autentisitet, integritet eller konfidensialitet.

Datasenteroperatør må sende oppdatert varsel dersom det skjer vesentlige endringer underveis i hendelsen, og når hendelsen er normalisert.

Ved konkrete og betydelige trusler med fare for brudd på autentisitet, integritet eller konfidensialitet skal datasenteroperatør varsle kundene om mulige vernetiltak eller avhjelpende tiltak som kunden kan iverksette. Dersom det er hensiktsmessig, skal datasenteroperatøren også informere om selve trusselen.

Virksomheten skal varsle kundene om planlagt arbeid som kan få konsekvenser for datasentertjenestene som tilbys.

Varsling for datasenteroperatør er videre beskrevet på Nkom sine hjemmesider for [datasenteroperatørers varslingsplikt](#). Varsling av hendelser til Nkom skjer via epost ekomvarsling@nkom.no. Det er også mulig å varsle p. Nkom beredskapsvakt på telefon 22 33 17 00. Det skal varsles i henhold til mal for hendelsesrapport, beskrevet gjennom Nkoms varslingskanal.

Datasenterforskriften § 2-9. Adgang til å pålegge datasentrene å ha nasjonal autonomi

Nasjonal kommunikasjonsmyndighet kan i en krise- og beredskapssituasjon pålegge datasenteroperatørene å drifte og vedlikeholde tjenestetilbudet med personell og tekniske løsninger i Norge.

Nasjonal autonomi innebærer at datasenteroperatører i en krise- og beredskapssituasjon skal ha evne til å drifte og vedlikeholde tjenestetilbudet, med personell og tekniske løsninger som er lokalisert på norsk territorium.

Samfunnet er i økende grad avhengig av datasentre for levering av kritiske tjenester. Denne avhengigheten utgjør en betydelig samfunnsmessig sårbarhet, der bortfall eller forringelse av tjenester kan få store konsekvens – også for grunnleggende nasjonale funksjoner.

Selv om utviklingen går i retning av mer komplekse og internasjonale verdikjeder, tilsier både den økte digitale avhengigheten og det endrede sikkerhetspolitiske landskapet at Norge må sikre en viss grad av nasjonal autonomi for å styrke beredskapsevnen. Norske datasentre og en robust digital infrastruktur legger til rette for at kritiske tjenester kan produseres i Norge, fremfor i datasentre i utlandet. Dette vil styrke den nasjonale kontrollen og autonomien.

Datasentre er en så grunnleggende viktig komponent i samfunnets infrastruktur at det i alvorlige situasjoner må være mulig å innføre nasjonal kontroll. Dersom ressursene som er nødvendige for å sikre kritiske kommunikasjonstjenester ikke kan underlegges norsk lovgivning og kontroll i en krise- eller krigssituasjon, kan de få alvorlige følger for nasjonal styringsevne.

Bestemmelsen er ikke til hinder for at datasenteroperatører i normal drift kan benytte ressurser utenfor norsk territorium. Imidlertid må virksomheten ha beredskap for å kunne opprettholde nødvendige nasjonale tjenester uten bruk av utenlandske ressurser dersom situasjonen krever det. Bestemmelsen gir myndigheten mulighet til pålegge datasenteroperatører å iverksette autonom nasjonal drift – et pålegg som kun kan gis i krise- og beredskapssituasjoner.

Datasenterforskriften § 2-10. Adgang til å pålegge prioritering av tjenestetilbud

Har datasentertjenestene stanset eller på andre måter vært utsatt for forstyrrelser, kan Nasjonal kommunikasjonsmyndighet, når det er nødvendig for å sikre offentlige interesser, pålegge datasenteroperatørene å prioritere viktige samfunnsaktører når normal drift skal gjenopprettes.

Bestemmelsen slår fast at Nkom kan fatte vedtak om prioritering av tjenestetilbud når normal drift skal gjenopprettes. Det er en forutsetning at det foreligger en situasjon hvor det er nødvendig for å sikre offentlige interesser.

4 Tilsyn

Nkom er tilsynsmyndighet etter ekomloven og datasenterforskrift. Det betyr at Nkom skal føre tilsyn med at kravene i lov og forskrift overholdes. I den forbindelse kan Nkom innhente informasjon og gjennomføre stedlig tilsyn. Nkom kan bl.a. fatte vedtak om pålegg om retting, tvangsmulkt og overtredelsesgebyr. Dette er regulert nærmere i ekomloven kap. 15 og kap. 3 i datasenterforskriften.